ТУСУР
TUSUR UNIVERSITY

Политики информационной безопасности

Управление информационной безопасностью. Лекция 2.1

5 Политики информационной безопасности

Раздел включает в себя 1 категорию и 2 меры обеспечения информационной безопасности:

5.1 Руководящие указания в части информационной безопасности
Цель: Обеспечить управление и поддержку высшим руководством информационной безопасности в соответствии с требованиями бизнеса, соответствующими законами и нормативными актами.

5.1.1 Политики информационной безопасности
Совокупность политик ИБ должна быть определена, утверждена руководством, опубликована и доведена до сведения всех работников организации и соответствующих внешних сторон.

5.1.2 Пересмотр политик информационной безопасности
Политики ИБ должны пересматриваться через запланированные интервалы времени или в случае происходящих существенных изменений для обеспечения уверенности в сохранении их приемлемости, адекватности и результативности.

Политика информационной безопасности

Политика информационной безопасности – это формализованный документ, который определяет подход организации к управлению информационной безопасностью, устанавливая принципы, цели и обязательства для защиты информации. Этот документ формирует основу для создания, внедрения и совершенствования системы менеджмента информационной безопасности (СМИБ).

Политика информационной безопасности – совокупность руководящих принципов, правил, процедур и практических приемов в области безопасности, которые регулируют защиту и распределение ценной информации на разных уровнях, а также управление этими процессами.

Политика информационной безопасности – это система документации, определяющая высокоуровневые цели, содержание и основные направления и устанавливающая правила, процедуры, практические приемы и руководящие принципы обеспечения ИБ активов организации, которыми она руководствуется в своей деятельности.

Основания для разработки политики ИБ

Основаниями для разработки политики ИБ в организации являются:

- требование руководства (демонстрация заинтересованности);
- требования законодательства и отраслевых стандартов;
- требования клиентов и партнеров;
- необходимость сертификации по стандартам;
- требования аудиторов;
- обеспечение конкурентоспособности;
- создание корпоративной культуры;
- экономическая целесообразность;
- следование тенденциям мировой практики.

Целью разработки политики ИБ является создание единой и общей основы для защиты информации в организации, включающей формирование единых правил работы с активами, защиты информации для всех участников информационного обмена, решения вопросов обеспечения ИБ в пределах корпоративной системы, а также вовлечение руководства и всего трудового коллектива в процесс обеспечения ИБ.

Как правило, основными задачами разработки политики ИБ являются описание целей и задач обеспечения ИБ на понятном пользователю языке, а также определение направления работы подразделения ИБ.

Исходные данные для разработки политики ИБ

Политики ИБ должны учитывать требования, порождаемые:

a) бизнес-стратегией;
b) нормативными актами, требованиями регуляторов, договорами;
c) текущей и прогнозируемой средой угроз ИБ.

Разработка политики ИБ производится на основе:

- опыта организации, сформировавшегося в области обеспечения ИБ;
- особенностей бизнес-процессов и применяемых технологий;
- идентификации и оценки защищаемых активов;
- проведенной оценки угроз, нарушителей и рисков ИБ;
- требований законодательства и руководящих документов в области ИБ;
- конкретных интересов и целей организации.

Содержание политики ИБ

Политика ИБ должна содержать положения, касающиеся:

a) определения ИБ, целей и принципов, которыми необходимо руководствоваться в рамках деятельности, связанной с ИБ;
b) определения ролей по менеджменту ИБ и распределения общих и конкретных обязанностей;
c) процессов обработки отклонений и исключений;
d) лиц, несущих ответственность за неисполнение политик ИБ.

В политике ИБ должны быть даны ответы на ключевые вопросы обеспечения ИБ:

- какие ресурсы подлежат защите?
- на каких должностных лиц распространяется действие политики ИБ?
- какова область действия политики ИБ?
- каковы основные правила обеспечения политики ИБ?
- каким образом оценивается выполнение требований политики ИБ?
- когда политика вступает в действие?
- какова необходимость внедрения политики ИБ?

Политики должны быть доведены до сведения всех работников и причастных внешних сторон в актуальной, доступной и понятной для предполагаемого читателя форме.

Содержание политики ИБ

Политика ИБ предприятия (организации) как документ верхнего уровня предполагает включение в его содержание следующих разделов:

1. Определение ИБ в терминах деятельности организации, области действия политики, целей, задач и принципов обеспечения ИБ организации.
2. Изложение намерения обеспечения ИБ, направленного на достижение указанных целей и на реализацию принципов обеспечения ИБ.
3. Общие сведения об активах, подлежащих защите, их классификация.
4. Модели угроз и нарушителей (внутренних и внешних), на противодействие которым ориентирована корпоративная политика ИБ.
5. Высокоуровневое изложение правил и требований по обеспечения ИБ, представляющих особую важность для организации.
6. Санкции и последствия нарушений.
7. Определение общих ролей и обязанностей (включая информирование об инцидентах ИБ).
8. Перечень частных политик ИБ, развивающих и детализирующих положения общей политики ИБ.
9. Положения по контролю реализации корпоративной политики ИБ организации.
10. Ответственность за реализацию и поддержку политики ИБ.
11. Условия пересмотра (выпуска новой редакции) политики ИБ.

Область действия политики ИБ

Область действия политики информационной безопасности четко определяет границы применимости всех правил и требований политики.

Область действия описывает на кого, на что и где распространяется действие политики информационной безопасности.

- Обеспечивает ясность и однозначность. Все сотрудники и заинтересованные стороны понимают, касаются ли их правила политики.
- Определяет границы оценки рисков. Оценка рисков информационной безопасности проводится именно в рамках установленной области. Нельзя защитить то, что не было включено в рассмотрение.
- Позволяет эффективно распределять ресурсы. Защита требует инвестиций. Четкие границы помогают понять, на что именно нужно направлять время, деньги и усилия.

Если в организации есть процессы или активы, которые не входят в область действия СМИБ, это должно быть явно указано и обосновано.

Область действия политики ИБ

1. Организационные границы.
Какие подразделения, филиалы и дочерние компании обязаны соблюдать политику. Какие виды деятельности и бизнес-процессы попадают под действие политики.

2. Географические и физические границы.
На каких территориях, в каких зданиях и офисах действует политика.

3. Информационные активы и технологическая среда.
Какие информационные активы подлежат защите (информация, программное обеспечение, техническое обеспечение, коммуникации, информационные системы и сервисы).

4. Люди (Персонал).
На каких лиц распространяется политика.

Пример:
Настоящая Политика информационной безопасности распространяется на все структурные подразделения ООО «Рога и копыта», включая центральный офис по адресу … и филиалы в … и …. Политика обязательна для исполнения всеми сотрудниками компании, а также внешними подрядчиками и временным персоналом, имеющим доступ к информационным активам Компании. Действие Политики распространяется на все информационные системы, средства вычислительной техники и информационные активы, принадлежащие ООО «Рога и копыта» и используемые в его хозяйственной деятельности.

Цели и задачи в политике ИБ

Цели – желаемые результаты, которых организация планирует достичь в области ИБ. Они должны быть стратегическими, измеримыми и согласованными с бизнес-целями.

Ключевые атрибуты правильных целей: поддержка бизнеса, измеримость, ориентация на результат.

Задачи – конкретные, часто оперативные действия и направления работ, которые необходимо выполнить для достижения поставленных целей.

Принципы – фундаментальные правила и убеждения, которые лежат в основе всех подходов, решений и действий в области ИБ. Это "красные линии", которые нельзя переходить.

Итоговый раздел в Политике ИБ должен выглядеть как четко структурированный список, который задает стратегию, тактику и идеологию защиты информации во всей организации.

Цели и задачи в политике ИБ. Пример

Основными целями обеспечения информационной безопасности в организации являются:

- Защита конфиденциальности, целостности и доступности информации и информационных активов от всех видов угроз, как внутренних, так и внешних, умышленных и непреднамеренных.
- Соблюдение требований применимого законодательства (в т.ч. 152-ФЗ О персональных данных, 187-ФЗ О безопасности КИИ), отраслевых стандартов и договорных обязательств.
- Обеспечение непрерывности бизнеса за счет минимизации ущерба от инцидентов информационной безопасности и снижения вероятности их возникновения.
- Формирование у персонала культуры ответственного отношения к информационным активам и требованиям информационной безопасности.

Для достижения поставленных целей в организации решаются следующие задачи:

- Регулярное проведение оценки рисков информационной безопасности для критичных активов и бизнес-процессов.
- Внедрение и поддержание эффективных мер защиты (организационных, технических, физических), адекватных выявленным рискам.
- Обеспечение осведомленности и компетенций персонала в области ИБ через программу обучения и информирования.
- Создание системы управления инцидентами ИБ, обеспечивающей их своевременное выявление, реагирование и восстановление.
- Организация непрерывного мониторинга и контроля эффективности СМИБ, включая проведение внутренних аудитов и пересмотра со стороны руководства.

Цели и задачи в политике ИБ. Пример

Деятельность по обеспечению информационной безопасности в организации основывается на следующих принципах:

- Принцип комплексности. Безопасность обеспечивается на всех уровнях (законодательном, организационном, программно-техническом) и на всех этапах жизненного цикла информационных систем.
- Принцип непрерывности. Процессы управления ИБ являются постоянными и систематическими, а не разовыми мероприятиями.
- Принцип своевременности. Меры по защите информации своевременно внедряются и адаптируются к изменяющимся угрозам и условиям ведения бизнеса.
- Принцип адекватности и экономической целесообразности. Уровень затрат на защиту информации должен быть соизмерим с возможным ущербом от нарушения информационной безопасности.
- Принцип персональной ответственности. Каждый сотрудник несет ответственность за соблюдение требований ИБ в рамках своих должностных обязанностей.
- Принцип разделения обязанностей и минимальных привилегий. Пользователям предоставляется ровно тот уровень доступа, который необходим для выполнения их рабочих задач, и не более.
- Принцип законности. Все мероприятия по защите информации осуществляются в строгом соответствии с действующим законодательством РФ.

«Верхнеуровневая» и «низкоуровневые» политики

Политика ИБ может включать различную документацию и подразделяется на политику верхнего уровня и частные политики ИБ.

На более низком уровне политику ИБ необходимо поддерживать политиками, относящимися к конкретным направлениям в обеспечении ИБ, которые далее предусматривают внедрение мер обеспечения ИБ и, как правило, структурируются для удовлетворения потребностей определенных групп в организации или для охвата определенных областей.

a) управление доступом;
b) категорирование и обработка информации;
c) физическая безопасность и защита от воздействия окружающей среды;
d) области, ориентированные на конечного пользователя:
    1) допустимое использование активов;
    2) "чистый стол" и "чистый экран";
    3) передача информации;
    4) мобильные устройства и дистанционная работа;
    5) ограничения на установку и использование программного обеспечения;
e) резервное копирование;
f) передача информации;
g) защита от вредоносных программ;
h) управление техническими уязвимостями;
i) криптография;
j) безопасность коммуникаций;
k) конфиденциальность и защита персональных данных;
l) взаимоотношения с поставщиками.

«Верхнеуровневая» и «низкоуровневые» политики

Примерами таких областей политик могут быть:

a) управление доступом (раздел 9);

b) категорирование и обработка информации (см. 8.2);

c) физическая безопасность и защита от воздействия окружающей среды (раздел 11);

d) области, ориентированные на конечного пользователя:

1) допустимое использование активов (см. 8.1.3);

2) "чистый стол" и "чистый экран" (см. 11.2.9);

3) передача информации (см. 13.2.1);

4) мобильные устройства и дистанционная работа (см. 6.2);

5) ограничения на установку и использование программного обеспечения (см. 12.6.2);

e) резервное копирование (см. 12.3);

f) передача информации (см. 13.2);

g) защита от вредоносных программ (см. 12.2);

h) управление техническими уязвимостями (см. 12.6.1);

i) криптография (раздел 10);

j) безопасность коммуникаций (раздел 13);

k) конфиденциальность и защита персональных данных (см. 18.1.4);

l) взаимоотношения с поставщиками (раздел 15).

Примеры политик со ссылками на разделы ГОСТ Р ИСО/МЭК 27002-2021

Разделы ГОСТ Р ИСО/МЭК 27002-2021 могут быть использованы как основа для формирования политики ИБ организации.

Политики ИБ

Потребность во внутренних политиках ИБ варьируется в зависимости от организации. Внутренние политики особенно полезны в крупных организациях, где лица, определяющие и утверждающие необходимый уровень мер обеспечения ИБ, отделены от лиц, реализующих эти меры; или в ситуациях, когда политика распространяется на многих людей или на многие функции в организации.

Политики ИБ могут быть оформлены в виде единого документа, например "Политика информационной безопасности", или в виде набора отдельных, но связанных документов.

Если какие-либо политики ИБ распространяются за пределы организации, то следует следить за тем, чтобы никакая конфиденциальная информация не была разглашена.

Пересмотр политик информационной безопасности

Политики ИБ должны пересматриваться через запланированные интервалы времени или в случае происходящих существенных изменений для обеспечения уверенности в сохранении их приемлемости, адекватности и результативности.

Каждой политике должен быть назначен владелец, за которым утверждена ответственность по разработке, пересмотру и оценке. Пересмотр должен включать в себя оценку возможностей для улучшения политик организации и подхода к менеджменту ИБ в ответ на изменения в среде организации, обстоятельств бизнеса, применимых нормативных и правовых актах или технической среде.

При пересмотре политик ИБ следует учитывать результаты проверок со стороны высшего руководства.

Высшее руководство должно утвердить пересмотренную политику.

Рассмотренные вопросы

- Политика информационной безопасности. Основания для разработки. Содержимое.
- Цели, задачи и принципы обеспечения ИБ согласно политики.
- Частные политики ИБ.

Почитать

- ГОСТ Р ИСО/МЭК 27002-2021

- Политика информационной безопасности предприятия – пример и советы по разработке https://www.securityvision.ru/blog/politika-informatsionnoy-bezopasnosti-predpriyatiya-primer-i-sovety-po-razrabotke/

ТУСУР
TUSUR UNIVERSITY

Всем спасибо – все свободны,

если нет вопросов!